



Risk: A Puzzle in an Enigma

Security 102



Risk Is N-dimensional

- Contractual
- Legal
- Regulatory
- Organizational
- Social
- Systemic
- Technical



Social Risks: Privacy

- Also a technical risk
 - Privacy requires security
 - Data compilations require distributed storage
- Most often attacked sites today: credit card databases
- Security and Privacy are integrated



What is Privacy

- Rights of seclusion
- Rights of autonomy
 - Multiple class action suits in process
- Rights of property
- Different concerns for different business models
- Users and companies will have a wide range of values for their data 'privacy'



Security & Privacy

- Confidentiality: information is not disclosed to unauthorized parties
- Privacy: information is not disclosed without consent of the subject
- Privacy requires security but security does not guarantee privacy
- Control results in liability



Systems Risks

- Technical reliability and survivability are systems-level issues. A single failed component should not caused a lost connection. No single weakest link.
- Organizational mechanisms must distribute technical authority with the same rationale and consideration as is done with paper systems. PKI does not replace risk control.



Technical Reliability Analysis

- For information to be reliable, transactions must have certain characteristics
 - Atomic
 - Consistent
 - Isolated
 - Durable



Atomic

- Fail completely or succeed completely
- No partial completion
- Never uncertain state



Consistency & Isolation

- Consistent
 - Everyone agrees on the outcome
- Isolated
 - No interaction between simultaneous separate



Durable

- Durable commitment
- Failure detection
- Recovery is possible



Security Failures At the Most Fundamental Level

- Software errors
- Basic protections
 - Best practice
 - Firewalls
 - Etc.



Computer Security Failures

- Coding errors
 - Logical flaws
 - » assume the only way to process Y is from process X
 - Implementation errors
 - » E.g. buffer overruns
- Solution: keep up to date with patches
- A technical problem requiring an organizational solution



Software Errors & Process Errors

■ Emergent errors

- Two pieces of software combined create a security problem
- Software in used in an unforeseen environment
 - » Social engineering
 - » Insider misuse

■ Solution:

- Assume systems fail
 - » Contingency planning
 - » Business plans which integrate with security plan

■ Every Procedure is a Risk Procedure



Security Goals

■ Confidentiality

- information is not disclosed to unauthorized parties

■ Integrity

- information is not altered

■ Authentication for access control



More Security Goals

■ Survivability:

- ability to provide service under attack, graceful degradation in the face of denial of service attacks

■ Non-repudiation:

- the actor cannot reasonably deny having taken an action, e.g. a promise of payment



Security Tools

■ Access lists

■ Auditing

■ Cryptography: A set of tools including

- Public key & private key
- Hash values
- Escrow



Hash Values

■ Compression of information into unique but unpredictable value

■ Verification without exact information

■ Hashing decreases the liabilities of long term data storage

- Legal
 - » Microsoft stored email most useful to the DoJ
- Technical
 - » Long term secure storage costly



Escrow

■ Escrow

- Data distributed to multiple agents
- Multiple locks, some subset of the keys is required to access the data
- Enables data access only in extreme situations

■ Can prevent data loss

- Political discussions about escrow can confuse the business decisions
- Government wants escrow for data in transit, companies want long term storage



Escrow & Data Security

■ Data in storage: Ideal Escrow Candidate

- Stored data key
 - » usually a symmetric key
 - » long-lived

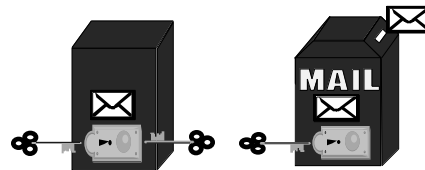
■ Data in use: Must be Decrypted

■ Data in transit: No Business Escrow

- Session key or communications key
 - » usually a symmetric or secret key used to provide confidentiality
 - » short-lived



Cryptography: Public Key and Private Key



Cryptography: Private Key or Symmetric

■ The same key encrypts & decrypts the information

- can provide authentication
- can provide access control
- cannot provide verification

■ Block & Stream Ciphers

- stream ciphers: x-or a data stream with a random string
- block ciphers: encrypt data in chunks



Cryptography: Public Key or Asymmetric

■ Two complementary keys: what is encrypted with one key must be decrypted with the other

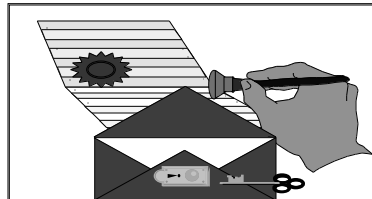
■ Knowledge of one key provides no information about the other key

■ Public keys are often linked to identity

- can provide authentication
- can provide access control
- can provide verification through *digital signatures*



Capabilities of Cryptography



Access Control

■

■

Party	Information	Trans Status	Credit History	Item Purchased
Customer		Read/Verify	Read/Verify	Read/Write
Merchant		Read/Write	Verify	Read
Merchant Employee		Read/Write	Verify	Read
Merchant Bank		Read	Read	Verify
Customer Bank		Read	Read/Write	Verify

Keys are the key

- **Secret key**
 - a private key corresponds to a public key and can be used for authentication, integrity, confidentiality and nonrepudiation
 - usually long-lived and identity-specific
- **Public key**
 - a publicized key that can provide confidentiality, integrity, and authentication
 - usually long-lived and identity-specific
- **Private key**
 - a long-lived key that is shared between a small number of parties that can provide authentication and confidentiality

Key Decisions

- **Who selects the keys?**
- **Who links the keys to authority (e.g. to pay, to bid,...)**
- **Who determines the key lifetime, key revocation and key storage practices**
- **Liability follows decision making**

A Problem

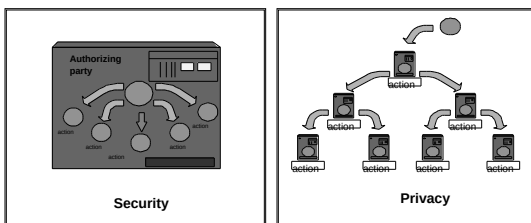
- **Covering thousands of employees at hundred of companies scalably**
- **Authenticating the employees initially is *not* the problem -- authenticating the employees in a continuous, reliable, distributed and secure manner *is*.**

Scalable Security

- **No bottlenecks**
 - Multiple key servers
- **Scalable transactions**
 - Limit expensive public key operations
- **System must scale**
 - Meaning the system can be expanded and backed up
 - Server load will not cause shutdown
 - Adding new organizations does not require changing the systems of old organizations

Security & Privacy as Paradigms

- **Security is top down & Privacy is bottom up**



- The mainframe is suited to the single organization
- PKI is suited to networked organizations

Security with the “Privacy Paradigm”

- **Web of Trust**
 - Each person has limited trust of another
 - Any person can vouch for others
- **Public Key Kerberos**
 - Using public keys two parties select a session or transaction key
 - Removes the bottleneck
- **Distributed trust**
 - Each organization assigns identity keys to employees
 - Each organization publishes credentials employees must have to bid, buy, etc.



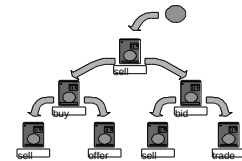
Public Key Management

- Public key infrastructures use public key management to distribute trust
- Public keys link a cryptographic key to a number
- This creates a *digital credential*
- Identity need not be linked to that credential



The Purpose of PKI

- Public key systems allow trust to be self-certifying and distributed IF key management works ...requiring an infrastructure



PKI

- A public key can be assigned a right
- A set of keys can be used together to authorize a right
 - Two signature for a check over \$100,000
 - Two PK signatures off a list provided by the company PKI to make a purchase over \$100,000
 - Two PKI signatures coming together to form a "thumbprint" (a hashed credential) can authorize an employee to take a set of actions



Business Strategy is a Security Document

- Zclient authenticates customer
- Customer posts item
- Zclient validates offering
- Offering is posted on Zclient
- Zclient checks customer electronic thumbprint provided by customer's employer
- Zclient checks exposure to failures of customer credential
- Zclient calculates risks of transaction failure and ensures Zclient exposure to customer employer is acceptable
- Customer posts item

Risks and security assumptions are embedded in business documents

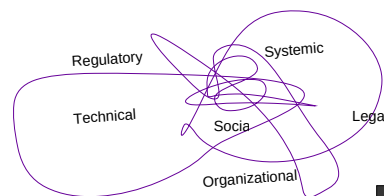


A Business Strategy Question

- Zclient has a customer, Dcustomer who has authorized \$10,000 to be spent by employees with Xcredential
- Dcustomer employee with Xcredential places bid of \$9,000 on item 1
- Dcustomer employee with Xcredential places a bid of \$4,000 on item 2
- Dcustomer employee places an order with an occasionally unreliable supplier of \$10,000
- How does Zclient evaluate its risk should Xcredential be subverted?



Risk Is



Understanding security will let you solve the risk puzzle.

